

Gestão de Risco de TIC

Objetivo da Aula

Conhecer os principais elementos utilizados na gestão de risco na tecnologia da informação e comunicação. Também definiremos alguns termos relacionados a gestão de risco, e compreenderemos a norma ABNT NBR ISO/IEC 27005:2011.

Apresentação

O objetivo desta aula é conhecer como as empresas trabalham a gestão de risco em TIC. A gestão de risco tem como principal foco o gerenciamento e o controle das potenciais ameaças ao negócio da empresa. O gerenciamento dos recursos humanos e materiais permite mitigar os riscos e tratá-los de forma controlada. Este processo é contínuo e observa tanto os riscos internos da empresa como os externos. Compreenderemos a norma ISO/IEC 27.005, que define o processo e as diretrizes da gestão de risco.

1. Definições de Risco, ABNT NBR ISO/IEC 27005:2011

Existem diversas maneiras de definir o conceito de risco de Tecnologia da Informação e Comunicação (TIC). Porém, como se trata de um conceito muito abrangente, se faz necessário aderir a alguma norma reguladora em prol da padronização. A norma ABNT NBR ISO/IEC 27005:2011 fornece diretrizes para a gestão de riscos de segurança da informação.

A norma 27005:2011 oferece um processo e uma estrutura genérica para avaliar e gerenciar os riscos de segurança da informação de forma sistemática. Esta norma foi feita com a função de ajudar organizações a identificar, avaliar e mitigar os riscos à segurança da informação, ajudando-as a tomar decisões informadas sobre como proteger seus ativos de informação.

Em seus termos mais simples, esta norma reguladora define riscos de segurança da informação como “a possibilidade de determinada ameaça explorar vulnerabilidades de um ativo ou conjuntos de ativos, causando impactos negativos à organização”. É válido destacar e definir alguns termos relacionados a gestão de risco:

- **Ativo:**
 - Recursos, processos, produtos ou infraestrutura que a organização reconhece como necessitando de proteção;
 - A perda de ativos pode afetar a confidencialidade, integridade ou disponibilidade de informações;
 - Seu valor é a soma de todos os aspectos relacionados a ele:
 - Desenvolvimento, manutenção, substituição, credibilidade, custos associados e valor de aquisição.
- **Risco:**
 - A probabilidade de uma ameaça explorar uma vulnerabilidade e causar danos a um ativo.
- **Proteção:**
 - Implementação de controles ou contramedidas para reduzir os riscos associados a ameaças específicas ou grupos de ameaças.
- **Vulnerabilidade:**
 - Ausência ou fraqueza de um sistema em proteção, tornando-o suscetível a ameaças;
 - Ameaças de baixo impacto podem se tornar significativas ou frequentes devido à exploração de vulnerabilidades.
- **Ameaça:**
 - Qualquer evento que tenha o potencial de causar efeitos indesejados em uma organização, podendo ser de origem natural ou provocada;
 - Podem ser eventos de baixo ou alto impacto e tudo mais que existe entre as duas possibilidades.
- **Brecha:**
 - Quando um mecanismo de segurança é contornado por uma ameaça;
 - Uma brecha explorada junto de um ataque pode significar uma invasão bem-sucedida.
- **Invasão:**
 - Quando um agente de ameaça obtém acesso à infraestrutura de uma organização ao contornar os controles de segurança estabelecidos, podendo causar danos diretos aos ativos.

• **Exposição:**

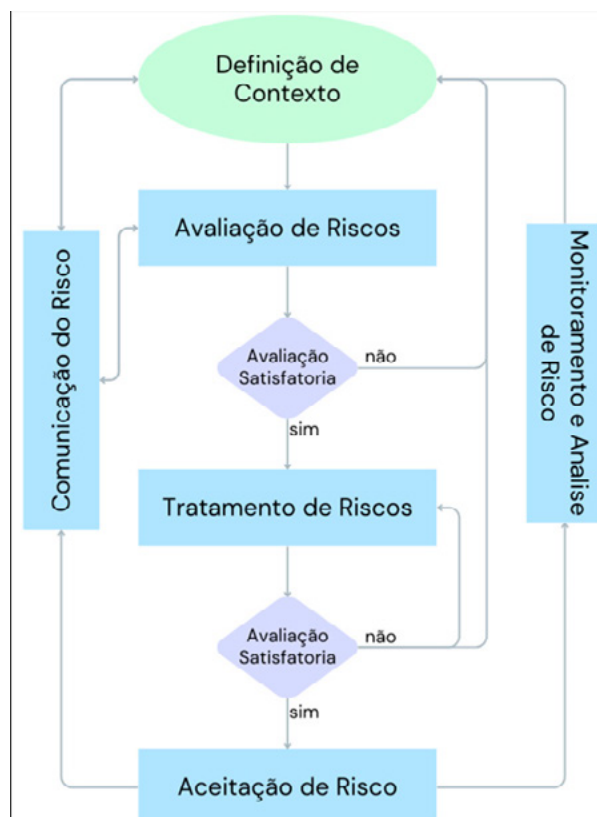
- A vulnerabilidade de um ativo a potenciais perdas devido a ameaças;
- Não significa que há perdas de ativos, apenas que há uma possibilidade de uma vulnerabilidade ser explorada.

2. Processo de Gestão de Risco 27005:2011

O processo genérico, implementado pela norma ABNT NBR ISO/IEC 27005:2011, utiliza seis fases: definição de contexto; processo de avaliação de riscos; tratamento do risco; aceitação do risco; comunicação e consulta do risco; monitoramento e análise crítica de riscos.

Estas seis fases formam um processo iterativo e contínuo, onde a organização deve revisitar regularmente suas avaliações de risco, estratégias de tratamento e planos de ação, para garantir que a segurança da informação permaneça eficaz e alinhada com os objetivos de negócio. Isso ajuda a proteger os ativos de informação e a reduzir os riscos de incidentes de segurança.

Figura 1: Processos de Gestão de Risco



Fonte: Adaptação da NBR ISO/IEC 27005 (2008, p. 5).

A figura 1 ilustra a ordem geral dos processos, mas não é capaz de demonstrar como a sua interatividade funciona e como é possível segmentar processos em grupos diferentes. Vamos entender passo a passo que fará mais sentido!

Começamos com a Definição de Contexto. Esta etapa do processo serve para que a organização estabeleça todo o contexto em que a gestão de riscos será realizada. Isso inclui a identificação de partes interessadas, como clientes, funcionários e reguladores, bem como a compreensão dos objetivos de negócios e as restrições que podem influenciar a gestão de riscos. Neste momento, o objetivo é ter uma compreensão abrangente do ambiente organizacional e dos fatores. Nesta etapa do processo, o funcionário de gestão de risco deve analisar todas as informações relevantes sobre a organização e o sistema a ser protegido, e então especificar critérios básicos para a gestão de risco, especificar o escopo e limites cujos riscos serão geridos.

Então, temos a função de efetivamente avaliar os riscos. Identificamos, analisamos e avaliamos os riscos relacionados à segurança da informação. Isso envolve a identificação de ativos críticos de informação, ameaças potenciais e vulnerabilidades. Armado dos critérios básicos, escopo e limites, e da organização, para gerência de risco (tudo entregue pela etapa anterior), deve ser elaborada uma lista de riscos avaliados e priorizados conforme os critérios estabelecidos. Isso tudo pode ser dividido em três segmentos, começando com a identificação de riscos:

- **Identificação de ativos:**

- Inventário, escopo e limites são essenciais para gerar uma lista de ativos que devem ser gerenciados frente aos seus riscos.

- **Identificação de ameaças:**

- Por meio de registros de incidentes e eventos de segurança, é possível formular uma lista de ameaças possíveis;
- Repare que “eventos de segurança” não diz respeito somente a ataques cibernéticos, mas pode também se referir a outros eventos que ameaçam a segurança dos ativos, como eventos climáticos (como inundações) ou de segurança da infraestrutura (como combate ao fogo), que também podem ser avaliados na gestão de risco, caso seja necessário.

- **Identificação de controles:**

- É necessário saber que tipos de controles e monitoramentos são utilizados e quais se planeja utilizar e implementar.

- **Identificação de vulnerabilidades:**

- Ameaças conhecidas, lista de ativos e lista de controles já existentes.

- **Identificação de consequências:**

- Analisando tudo produzido anteriormente, é possível criar uma lista com cenários e incidentes, e então projetar quais seriam suas consequências aos ativos e aos processos do negócio.

Então, entramos na análise de riscos:

- **Estimativa de consequências:**

- Utilizando a lista feita pela identificação de consequências, é possível avaliar o impacto que esses possíveis eventos trariam à organização.

- **Estimativa da probabilidade de incidente:**

- Considerando a lista de controle e de consequências, é possível estimar a chance de incidentes ocorrerem, gerando uma lista de probabilidade e prioridades.

- **Estimativa do nível de risco:**

- Utilizando a lista de consequências em conjunto com a de probabilidade, é feita uma valoração, onde se atribui níveis aos riscos.

Por fim, terminamos na avaliação de riscos, que utiliza as listas produzidas, os critérios declarados no contexto e a aceitação do risco e, então, gera efetivamente a lista de riscos priorizados, conforme todos os critérios de avaliação definidos em relação aos cenários de incidentes que podem levar a estes riscos.

Repare que, apesar de tratarmos de um processo, podemos observar que ele não é completamente linear. Como o diagrama revela, a avaliação de riscos dialoga com a comunicação de riscos à diretoria constantemente, que pode alterar definições de contexto, caso venha se fazer necessário. Logo após a produção da lista de avaliação de riscos, chegamos a um ponto de decisão, o primeiro deste processo; caso esta lista seja avaliada como insatisfatória, é necessário retornar à definição de contexto e recomeçar o processo.

Caso o resultado seja considerado satisfatório, passamos para a etapa de tratamento de risco. Com os riscos identificados e avaliados, a organização precisa desenvolver estratégias para tratar esses riscos. As estratégias podem incluir a mitigação dos riscos, a transferência dos riscos, a aceitação dos riscos ou a rejeição do risco.

A mitigação de riscos envolve a implementação de medidas e controles novos, que reduzem a probabilidade de ocorrência ou o impacto de um risco. Já a transferência de riscos é quando a organização transfere parte ou todo impacto dos riscos para outra entidade. Geralmente, o impacto é calculado em termos financeiros, sendo transferido por meio de seguros.

Em alguns casos, é possível que a organização decida aceitar conscientemente um risco. Isso se dá quando o custo de mitigar riscos supera o impacto das ameaças, no entanto, é necessário que essa decisão seja tomada com base nas informações levantadas previamente. É possível, no entanto, que o impacto seja tão alto que ele se torne completamente inaceitável, o que pode fazer a organização evitar completamente e então optar por outros meios, que não gerem este mesmo risco. Como sempre existem riscos latentes ou residuais, geralmente, alguns riscos devem ser aceitos para a continuidade do processo, pois a organização não possui recursos infinitos para combater ameaças.

Por fim, a etapa de tratamento de riscos deve gerar um relatório que detalhe o plano de tratamento de risco e uma lista com os riscos residuais. Ao mesmo tempo que seguimos na caminhada do processo como um todo, este plano e lista devem ser entregues ao processo de monitoramento.

Novamente, chegamos a um ponto de decisão, onde o relatório gerado pelo tratamento de riscos pode ser considerado satisfatório ou não. Caso seja considerado insatisfatório, podemos recomeçar a etapa de tratamento ou temos de retornar à definição de contexto.

No caso de o relatório ser considerado satisfatório, chegamos à etapa de aceitação do risco. Com o plano de tratamento de riscos e a avaliação de riscos residuais em mãos, é necessária a aceitação formal dos riscos remanescentes e o OK para o plano de tratamento ser implementado. É necessário que a aceitação seja documentada, explicitando todos os riscos que estão sendo aceitos pela organização.

Por fim, o processo “termina” em duas etapas simultâneas, que estão sempre sendo efetuadas ao longo do processo: a de comunicação do risco e a de monitoramento e análise de risco. A comunicação de risco é a fase em que a organização comunica as informações relacionadas aos riscos de segurança da informação a todas as partes interessadas relevantes. Isso inclui relatar os resultados da avaliação de riscos, as estratégias de tratamento e as decisões de aceitação. A comunicação eficaz é crucial para garantir que todas as partes interessadas tenham conhecimento dos riscos e das medidas de mitigação a serem implementadas.

Já o monitoramento e análise crítica de riscos, que pode ser considerada efetivamente a fase final do processo, envolve o acompanhamento contínuo dos riscos e das medidas de tratamento implementadas. Isso inclui a coleta de dados relevantes, análise de tendências e revisão periódica do processo de gestão de riscos. A análise crítica de riscos permite à organização ajustar suas estratégias de tratamento e garantir que a segurança da informação continue sendo eficaz ao longo do tempo.

Estas seis etapas, detalhadas pela norma ABNT NBR ISO/IEC 27005:2011, formam um processo iterativo e contínuo, onde toda a organização deve revisitar regularmente suas avaliações de risco, estratégias de tratamento e planos de ação, para garantir que a segurança da informação permanece eficaz e alinhada com os objetivos de negócio. Isso ajuda a proteger os ativos de informação e reduzir os riscos de incidentes de segurança. Repare como o diagrama da figura 1 facilita separar as etapas e enxergar as evoluções do processo iterativo, que pode ficar indo e voltando, em diferentes momentos, por diferentes motivos.

3. Métodos de Avaliação de Risco

Como a norma 27005:2011 foi feita pensando em ser abrangente, o processo é bem detalhado, porém nunca é especificado, para que seja possível se encaixar em qualquer organização, de acordo com seus contextos e definições específicas.

Existem vários métodos de análise e avaliação de risco que podem ser aplicados em diferentes contextos de segurança da informação, porém, aqui, vou destacar dois dos mais comuns: análise quantitativa de riscos e análise qualitativa de riscos.

3.1. Análise Qualitativa

A análise qualitativa de risco é empregada para classificar um risco por meio de termos ou palavras (como baixo, médio ou alto risco), que procuram quantificar o impacto das consequências de um risco específico, considerando as probabilidades de sua ocorrência. O objetivo deste método é adquirir uma compreensão mais aprofundada do evento de segurança, por meio da coleta de dados e das características apresentadas.

Este método é mais comumente utilizado quando estamos nas fases iniciais do processo, auxiliando na identificação dos riscos relativos, que podem ter um alto nível crítico. Ele é rápido e fácil de ser efetuado, permitindo que a organização utilize a experiência e conhecimento do gerente de riscos sobre o ativo a ser avaliado.

Figura 2: Análise Qualitativa

		Impacto		
		Baixo	Médio	Alto
Probabilidade	Baixa	Baixo Risco	Baixo Risco	Médio Risco
	Média	Baixo Risco	Médio Risco	Alto Risco
	Alta	Médio Risco	Alto Risco	Alto Risco

Fonte: Elaboração própria (2024).

Como este método depende da experiência do gestor, ele tem o problema de ser altamente tendencioso, tanto na probabilidade quanto na definição de impacto.

3.2. Análise Quantitativa

Já a avaliação quantitativa do risco se concentra em dados, fatos e medidas mensuráveis, com embasamento matemático e computável. Por depender de medidas e efetuar uma análise mais minuciosa, este método é mais custoso e lento, porém gera resultados mais confiáveis e imparciais.

Geralmente, o resultado desta análise pode ser expresso em termos de perdas financeiras relacionadas ao evento de segurança sendo analisado. Utilizando conceitos de estatística e probabilidade, é possível calcular estimativas de possíveis perdas em cada cenário.

Considerações Finais da Aula

Nesta aula, exploramos as definições de risco na gestão de segurança da informação, conforme a norma ABNT NB ISO/IEC 27005:2011. Esta norma fornece diretrizes fundamentais para avaliar e gerenciar riscos de segurança da informação de forma sistemática, contribuindo para a tomada de decisões informadas sobre a proteção de seus ativos de informação.

Em nosso breve estudo, definimos termos essenciais relacionados à gestão de risco, como ativos, riscos, proteção, vulnerabilidade, ameaças, brechas e exposições. Compreender estes conceitos é fundamental para uma gestão eficaz de risco de segurança da informação.

O processo de gestão de riscos, delineado pela norma 27005:2011, foi detalhado em seis fases: definição de contexto, processo de avaliação de riscos, tratamento do risco, aceitação do risco, comunicação e consulta do risco, e monitoramento e análise crítica de riscos. Cada etapa foi explicada, tendo sido ilustrado como elas se relacionam umas com as outras de forma interativa.

Por fim, discutimos dois métodos de avaliação de risco: a análise qualitativa, que se baseia em termos subjetivos para classificar riscos, e a análise quantitativa, que utiliza valores numéricos para uma avaliação mais precisa.

Em resumo, a gestão de riscos de segurança é um processo vital para proteger ativos e garantir a continuidade dos negócios.

Material Complementar



Gestão de Risco no Tribunal de Contas da União

2024, TCU.

Site que apresenta a Gestão de Risco no TCU – Tribunal de Contas da União.

Disponível em: <https://portal.tcu.gov.br/planejamento-governanca-e-gestao/gestao-de-riscos/gestao-de-riscos/governanca-e-gestao-de-riscos.htm>. Acesso em: 26 jan. 2024.

Referências

CONSELHO de Justiça Federal. **Manual de Gerenciamento de Risco**. 2022. Disponível em: <https://www.cjf.jus.br/observatorio2/temas/metodologias-de-gestao/manual-de-gerenciamento-de-riscos-do-cjf>. Acesso em: 1º ago. 2023.

O que é gerenciamento de risco? **International Business Machines Corporation**, 2024. Disponível em: <https://www.ibm.com/br-pt/topics/risk-management>. Acesso em: 1º ago. 2023.